



Mary Wang
Executive Director of Open Chain Project, Linux Foundation

Beijing ,Aug,2026

[Location], [Date]

Antitrust Policy Notice

Linux Foundation meetings involve participation by industry competitors, and it is the intention of the Linux Foundation to conduct all of its activities in accordance with applicable antitrust and competition laws. It is therefore extremely important that attendees adhere to meeting agendas, and be aware of, and not participate in, any activities that are prohibited under applicable US state, federal or foreign antitrust and competition laws.

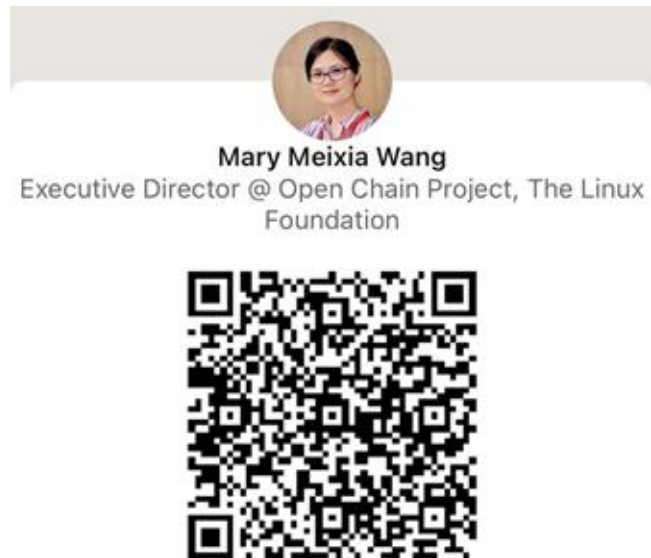
Examples of types of actions that are prohibited at Linux Foundation meetings and in connection with Linux Foundation activities are described in the Linux Foundation Antitrust Policy available at <http://www.linuxfoundation.org/antitrust-policy>. If you have questions about these matters, please contact your company counsel, or if you are a member of the Linux Foundation, feel free to contact Andrew Updegrove of the firm of Gesmer Updegrove LLP, which provides legal counsel to the Linux Foundation.



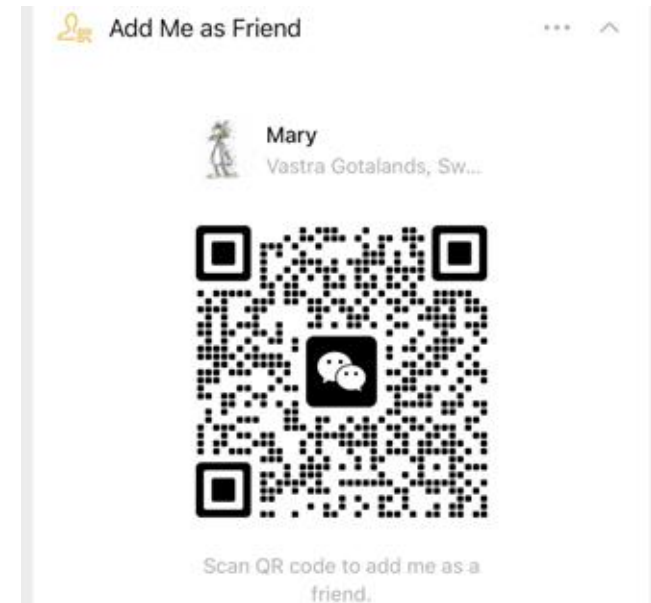
Who am I

Mary Wang
Executive Director of Open Chain Project, the Linux Foundation

LinkedIn



WeChat



What Is OpenChain

Vision

Our vision is a **supply chain** where open source is delivered with trusted, transparent and consistent process management information.

Mission

Our mission is to make that happen.



OpenChain Community



Meet Our Ambassadors:

Meet Our Ambassadors:



For more information, please visit:

<https://openchainproject.org/community>

What is OpenChain

ISO/IEC 5230 (License Compliance)



-
-
-

Flexible program size

Covering:

Inbound processes

Internal processes

Outbound processes

Standards about process *points*

Not about process *content*

ISO/IEC 18974 (Security Assurance)



We help organizations adopt ISO 5230 and ISO 18974

Adopt the global standard for open source license and security compliance. Get started with our comprehensive resources today.

Get Started Now

<https://openchainproject.org/get-started>



OpenChain Business Operation

The OpenChain Business Operations Study Group is a community forum for exploring new ideas, identifying emerging requirements, and discussing potential projects that can help shape the direction of the OpenChain Project. The group is open to everyone. You're welcome to join the discussion, share challenges and opportunities, and learn from others.

For more information, see <https://openchainproject.org/openchain-business-operations>



OpenChain WorkGroups

Japan WG

Korea WG

China WG

Germany WG

India WG

Taiwan WG

UK WG

Meridian 22 WG

Specification WG

Education WG

AI WG

SBOM WG

Tooling WG

Automotive WG

Telco WG

Business Study WG

OpenChain CRA Requirement & Checklist

CRA

The CRA (Regulation (EU) 2024/2847) establishes mandatory cybersecurity requirements for products with digital elements placed on the EU market.

Organizations that develop, maintain, or distribute software with digital elements must ensure their products meet essential cybersecurity requirements throughout the product lifecycle.

AI ACT

OpenChain **CRA Requirement & Checklist** is ready for review!

[AI SBOM Compliance Management](#)



OpenChain is the **strategic bridge** to global regulatory compliance in CRA.

OPENCHAIN

Why This Guide Exists

This guide defines the key requirements of a quality AI SBOM Compliance program — **a benchmark for building trust between organizations that exchange AI solutions.**

It focuses on **what and why** rather than how and when — giving organizations of every size and market the flexibility to build a program that fits their own scope and goals.

This is a living document — under active development, shaped by ongoing community input.

PRIMARY REFERENCES

ISO/IEC 5230:2020

Open source license compliance

ISO/IEC 42001:2023

AI management systems

ISO/IEC 5962:2021

SPDX specification

Scope of the Document



This document specifies the key requirements for managing AI compliance in the supply chain — specifically through the use of an AI Bill of Materials (AI SBOM) as the mechanism for demonstrating that compliance.

Code

Model Weights

Training Data

Testing Data

Verification Data

Licenses

The AI SBOM is the connective thread across every element of the system's supply chain.

Ten Pillars of the Program

01

Policy

02

Competence

03

Awareness

04

Program Scope

05

License Obligations

06

Transparency
Obligations

07

Access

08

Effectively
Resourced

09

AI SBOM

10

Governance

Policy & Competence



Policy

A written, internally communicated policy must govern AI SBOM compliance — shaped by business strategy, legal requirements, and the level of risk appropriate to the use case.

VERIFICATION MATERIALS

- A documented policy meeting the requirements
- A documented procedure to raise participant awareness (training, wiki, etc.)



Competence

Organizations must identify roles and responsibilities across governance, security, safety, privacy, development, and supplier management — ensuring each participant is qualified.

VERIFICATION MATERIALS

- Documented roles & responsibilities per participant
- Competency requirements defined for each role
- Evidence of assessed competence, reviewed periodically

Awareness & Program Scope



Awareness

Program participants must be aware of the AI SBOM policy, the relevant business objectives, their own contribution to the program's effectiveness, and the consequences of non-conformance.

Verification: documented evidence of assessed awareness covering objectives, individual contribution, and implications of non-conformance.



Program Scope

A program's scope is declared per organization — it may govern a single product line, a department, or the whole organization, fitting real operational boundaries.

Verification: a written statement clearly defining the scope and limits of the program.

License & Transparency Obligations



License Obligations

A process must review identified licenses across an AI system's code, weights, and datasets — plus the system's own license — to determine obligations, restrictions, and rights, given the intended use.

An AI system is often trained on other AI systems, each carrying its own license — traceable through the system's Model Tree.



Transparency Obligations

A process must review regulatory transparency obligations relating to training, testing, and verification datasets, based on the model's intended use.

Where disclosure obligations to downstream recipients arise, appropriate risk mitigation measures should be undertaken.

Access & Effectively Resourced



Access

Maintain a process to respond effectively to external AI SBOM compliance inquiries, and publish a means for third parties to reach the organization — such as a published contact address.



Effectively Resourced

- Accountability assigned for program execution
- Sufficient time and funding allocated to tasks
- Legal expertise accessible where needed
- A process exists to resolve compliance issues

RATIONALE

Ensures compliance inquiries can always be answered, and that program responsibilities are properly staffed, funded, and kept current as best practices evolve.

SECTION 3.9

The AI System Bill of Materials



A process must exist for creating and managing an AI SBOM — in any format (e.g. SPDX, CycloneDX) — that accounts for inbound materials from third parties.



WHY IT MATTERS

The bill of materials underpins systematic review and approval of the system — making its obligations and restrictions visible and traceable across the supply chain.

Governance



Organizations need a governance framework — spanning policies and practices — to ensure AI systems are developed, deployed, and managed responsibly across their full lifecycle.

KEY REGULATORY REFERENCE POINTS

EU AI Act

Hiroshima AI Process

Global AI Governance Initiative (China)

Verification: a documented AI governance framework covering the AI system's lifecycle, reviewed periodically.

Governance



Topic	EU AI Act	Hiroshima AI Process	China Initiative
Risk-based regulation	✅ Core principle	⚠️ Recommended	⚠️ Encouraged
AI safety	✅	✅	✅
Transparency	✅ Mandatory in many cases	✅ Recommended	✅ Promoted
Human oversight	✅ Required for high-risk AI	✅ Recommended	✅ Promoted
Fundamental rights	✅ Strong emphasis	⚠️ Mentioned	⚠️ General human-centered approach
Security	✅	✅ Strong focus	✅ Strong focus

Building Trust Across the AI Supply Chain



The OpenChain Project maintains ISO/IEC 5230 (open source license compliance) and ISO/IEC 18974 (security assurance), plus over 1,000 supporting documents — policy templates, checklists, and training guides — all free.

www.openchainproject.org • Guide licensed under Creative Commons Attribution 4.0 (CC-BY-4.0)

Thank you!



SCAN TO VISIT OUR WEBSITE



openchainproject.org



Follow OpenChain on LinkedIn



linkedin.com/company/openchain

